

HOME SHIELD

HOME SMART-DEVICE (IoT)

SECURITY ASSESSMENT REPORT

Penetration Test of Connected Home Devices

Prepared for:

The Homeowner

Prepared by:

Independent Home Network Security Assessment Team

Assessment Date:

31 August 2026

CONFIDENTIAL

This report contains sensitive information about the security of devices in this home, including a working (now changed) camera password. It should be stored securely and shared only with people who need it.

Contents

- 1. Executive Summary3
- 2. Summary of Findings3
- 3. Detailed Findings.....5
 - 3.1 Security Camera Protected by a Weak, Default Password5
 - 3.2 Smart Lights Can Be Controlled Without Any Password6
 - 3.3 Home Automation Control Panel Is Exposed on the Network7
 - 3.4 Smart-Device Messages Are Sent Unencrypted8
 - 3.5 Smart Hub Shares Internal Status Information Freely9
 - 3.6 Streaming Server Exposes More Network Ports Than Necessary10
 - 3.7 No Separation Between Smart Devices and Everyday Devices11
- 4. General Recommendations for the Household 12
- 5. Technical Appendix 13
 - 5.1 Scope and Methodology.....13
 - 5.2 Evidence Summary by Finding.....13
 - 5.3 Technical Remediation Guidance15
 - 5.4 Notes and Limitations.....16

1. Executive Summary

This report presents the results of an authorized security assessment ("penetration test") carried out against the smart-device network in this home. The purpose of the assessment was simple: to find out what someone could see or do if they gained access to the home's network — for example, through a compromised guest device, an insecure Wi-Fi password, or a malicious app on a phone already connected to the network — and to report back before that happens for real.

The devices covered in this round of testing were the smart indoor security camera, the smart lighting system, the home automation hub, and the underlying "messaging system" that lets these devices talk to one another. A physical door lock was added to the home after this assessment was completed and is therefore not covered here; it is recommended as the subject of a follow-up assessment.

The headline result is that several devices could be accessed, viewed, or controlled by anyone connected to the home network, without needing to prove who they were. Most seriously, the indoor security camera's live video and audio feed could be viewed using a very weak, easily guessed password. The smart lights could also be turned on and off by anyone on the network with no password at all.

The good news is that none of these issues require buying new equipment. Most of the risk can be significantly reduced by changing default passwords, separating smart devices onto their own network, and asking whoever installed the system to turn on the security features that already exist in the software but were left switched off.

How to Read This Report

- Section 2 gives a one-page, colour-coded summary of every issue found and how severe it is.
- Section 3 explains each issue in plain language: what it means, which device it affects, and what it could allow someone to do.
- Section 4 lists simple, general steps to make the whole home network safer.
- Section 5 (Technical Appendix) is written for a technician or anyone comfortable with networking terms. It contains the actual commands, evidence, and detailed configuration fixes.

2. Summary of Findings

Seven issues were identified during this assessment. Each is rated by severity — how serious the issue is if left unaddressed — using the colour scale below.

Critical	High	Medium	Low
Immediate action needed — an active, easy-to-exploit risk to privacy or safety.	Should be fixed as soon as practical — a real risk with a clear route to abuse.	Worth fixing — lower likelihood or impact on its own, but adds up.	Good hygiene — minor exposure, low likelihood of direct harm alone.

#	Finding	Device(s) Affected	Severity	Fixable by Homeowner?
1	The security camera is protected only by a very weak, factory-default password.	Indoor security camera (video & audio)	Critical	Yes
2	Smart lights can be turned on or off by anyone on the network — no password is asked for at all.	Smart lighting system	High	Partly
3	The home automation control panel is reachable by any device on the network, and it is not confirmed to be password-protected.	Home automation hub	High	Partly
4	Commands and messages between smart devices travel across the network unencrypted and can be read by anyone listening in.	Smart-hub messaging system (all connected devices)	Medium	No
5	The smart hub freely shares internal operational details with anyone who asks, without checking who is asking.	Smart-hub messaging system	Low	No
6	The video-streaming server exposes more network doors (ports) than it needs to, increasing the ways in that need watching.	Video-streaming server	Low	No
7	Every smart device sits on one flat network alongside laptops, phones, and guest devices, with nothing keeping them apart.	Whole home network	Medium (root cause)	Partly

3. Detailed Findings

This section explains each issue in everyday terms: what was found, which device it affects, what someone could actually do with it, and what — if anything — you can do about it yourself right now.

3.1 Security Camera Protected by a Weak, Default Password

SEVERITY: Critical

Device(s) affected: Indoor security camera (live video and audio stream)

What we found

The camera's video and audio feed was reachable over the home network, and it accepted a very simple, factory-style username and password combination to view the live stream. Once connected, both live video (640×360, 30 frames per second) and live audio were available in full, and the stream also played back smoothly in standard video software.

Why this matters

This is the most serious finding in this assessment. A camera password this weak is one of the first things an attacker — or an automated scanning tool — will try. Anyone who guesses or already knows this password, whether from inside the home network or (if the camera is ever exposed to the internet) from anywhere in the world, can silently watch and listen to whatever the camera sees, including when people are home, daily routines, and conversations picked up by the microphone. This is a direct risk to household privacy and physical safety.

What you can do about it

These steps do not require technical expertise:

- Change the camera's password immediately to a long, unique password that isn't used anywhere else — a password manager can generate and store one for you.
- If the camera came with a generic installer or "admin" account, replace or disable it rather than just changing its password, if the camera's app allows this.
- Check the camera manufacturer's app for a firmware update and install it — updates often close off other known issues.
- Confirm the camera is not configured to be reachable directly from the internet (no "port forwarding" for the camera on your router) unless you specifically set that up through the manufacturer's official app.

3.2 Smart Lights Can Be Controlled Without Any Password

SEVERITY: High

Device(s) affected: Smart lighting system (living room light, and by extension any light or plug using the same hub)

What we found

The smart hub that controls the lighting was found to accept commands from any device on the network without asking for a username or password. Using nothing but the light's own address, it was possible to turn the living room light off and back on again at will.

Why this matters

On its own, someone flicking a light on and off is a nuisance rather than a disaster — but it demonstrates that the hub will accept instructions from anyone, not just the household's own app. The same lack of a password would apply to any other device wired into this hub in future (plugs, blinds, thermostats, and similar), and it also means the hub cannot tell the difference between a family member's phone and an unwelcome visitor's laptop. It is also a classic sign that a home system was set up for convenience during installation and never "locked down" afterwards.

What you can do about it

These steps do not require technical expertise:

- Ask whoever installed or maintains the smart-home system to confirm that a username and password are required before any device can send it commands — this is a setting, not a hardware limitation, so it can usually be turned on without buying anything new.
- In the meantime, keep the number of devices allowed onto the home Wi-Fi to a minimum, and see the guest-network suggestion in Section 4.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

3.3 Home Automation Control Panel Is Exposed on the Network

SEVERITY: High

Device(s) affected: Home automation hub (the control panel used to programme and manage all connected devices)

What we found

A web-based control panel used for setting up and automating the smart home was found to be reachable by any device on the home network. This assessment identified that the panel exists and is exposed; as a deliberate, careful choice, no attempt was made in this phase to log in or bypass any password screen, so it is not yet confirmed whether it is properly protected.

Why this matters

This type of control panel is normally the most powerful thing in a smart home — it is typically used to view, create, and edit the automation "recipes" that connect every other device together. If it turns out not to be properly password-protected, whoever can reach it on the network could potentially reprogram how every connected device behaves, not just view or toggle one device at a time. Because of that potential impact, this is treated as a high-priority item pending confirmation, even though it was not exploited during this test.

What you can do about it

These steps do not require technical expertise:

- Ask your installer or technician to confirm, in writing, that a strong username and password are required to open this control panel, and that it cannot be reached from outside the home without a secure remote-access method (such as a VPN).
- Request a short, dedicated follow-up test focused solely on this panel before treating it as resolved.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

3.4 Smart-Device Messages Are Sent Unencrypted

SEVERITY: Medium

Device(s) affected: Smart-hub messaging system — affects every device that talks through the hub, including the lighting system

What we found

Network traffic between devices and the smart hub was captured and inspected. The content of the messages — including which device was being addressed and what instruction was being sent — was fully readable in plain text, with no encryption in place.

Why this matters

Anyone with access to the home network (again, this could be a compromised laptop, a malicious app, or an insecure guest device) can watch exactly what commands are flowing between your smart devices in real time. On its own this mainly exposes patterns of behaviour — for example, when lights typically turn on or off, which can hint at when a home is occupied. Combined with Finding 2, it also means there is nothing to stop those same messages being copied and re-sent by someone else.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

3.5 Smart Hub Shares Internal Status Information Freely

SEVERITY: Low

Device(s) affected: Smart-hub messaging system

What we found

The smart hub was found to publish internal operating statistics — such as how many devices are currently connected, how many messages have been exchanged, and how much information it is currently storing — to anyone who asks, without checking who is asking.

Why this matters

This information does not directly expose camera footage or let someone control a device by itself, but it is useful reconnaissance: it tells a would-be attacker how "busy" and how valuable a target the system is, and can help them judge whether other attempts (like the ones above) are worth pursuing further.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

3.6 Streaming Server Exposes More Network Ports Than Necessary

SEVERITY: Low

Device(s) affected: Video-streaming server (the component behind the camera feed)

What we found

In addition to the main camera stream, the server behind it was found to be listening on several additional network ports for related streaming and status functions, one of which presented a security certificate valid for an unusually long ten-year period — well beyond normal good practice.

Why this matters

Every additional open port is another door that has to be kept secure. None of these extra ports were found to leak camera footage directly during this test, but each one is a piece of unnecessary "attack surface" — software that could contain its own separate flaw in future and does not need to be reachable by every device on the network today.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

3.7 No Separation Between Smart Devices and Everyday Devices

SEVERITY: Medium (root cause)

Device(s) affected: The whole home network — every device, smart and personal, shares the same network

What we found

All of the devices above, plus every laptop, phone, and guest device that connects to the home Wi-Fi, sit on the same flat network with no barriers between them. There is nothing in place to stop one device "seeing" and talking directly to another.

Why this matters

This is the issue that makes every other finding in this report worse than it needs to be. If any single device on the network is ever compromised — a guest's phone with malware, an unrelated cheap smart-plug with its own flaw, or a laptop that visits the wrong website — that device has a direct, unobstructed path to the camera, the lights, and the automation hub described above. Keeping smart devices on their own separate network is one of the single most effective things a household can do, and directly reduces the real-world risk of Findings 1–6 even before each one is individually fixed.

What you can do about it

These steps do not require technical expertise:

- Check whether your home Wi-Fi router or mesh system has a built-in "Guest Network" or "IoT Network" option (most routers sold in the last few years do) and move smart devices onto it, keeping personal laptops and phones on the main network.
- Give that separate network its own Wi-Fi name and password, and don't share that password for anything other than smart devices.

A full technical fix for this issue is in Section 5 (Technical Appendix) — it involves reconfiguring device software and is best done by, or with, whoever installed the system.

4. General Recommendations for the Household

These are not tied to a single finding above — they are good habits that reduce risk across the whole smart home, and none of them require technical training.

- Change every default password. If a device came with "admin", "12345", or a password printed on a sticker, change it before anything else.
- Use a password manager to create and store a long, unique password for each device and app — reusing the same password across devices means one leak affects everything.
- Turn on a separate Guest or IoT Wi-Fi network for smart devices, keeping them apart from personal laptops and phones (see Finding 7).
- Keep device apps and firmware up to date — turn on automatic updates where the manufacturer's app allows it.
- Periodically check the list of devices connected to your Wi-Fi (most router apps show this) and investigate anything you don't recognise.
- Avoid exposing any smart device directly to the internet ("port forwarding"). Use the manufacturer's official app or a secure remote-access method instead.
- When in doubt, ask your installer or a trusted technician to confirm that a device's security settings — password protection, encryption, and access limits — are switched on, not just available.

5. Technical Appendix

This section is written for a technician, installer, or reader comfortable with networking terminology. It documents the methodology, the supporting evidence for each finding above, and the specific configuration changes needed to remediate them.

5.1 Scope and Methodology

Testing was performed from an authorized position on the home's device network, simulating the perspective of an already-connected but untrusted device (e.g. a compromised guest device or a malicious app) rather than an external internet-based attacker. Only non-destructive read actions and one benign control action (toggling a light) were performed; no attempt was made to authenticate to, or bypass authentication on, the home automation control panel identified in Finding 3, and no destructive commands were issued to any device.

Target network: 192.168.50.0/24

Attacker/testing host: 192.168.50.10

Target host (smart-home services): 192.168.50.20

Tools used: Nmap 7.99 (host and service discovery), Mosquitto client utilities mosquitto_sub / mosquitto_pub (MQTT interaction), tcpdump (packet capture), ffprobe / ffmpeg (RTSP stream validation).

5.2 Evidence Summary by Finding

Finding 1 — Weak RTSP credentials (Critical)

The RTSP stream was accessed successfully with trivially weak, default-style credentials embedded in the connection URI:

```
ffprobe rtsp://admin:12345@192.168.50.20:8554/cam
```

This returned a live H.264 (640x360, 30fps) video stream with AAC-LC stereo audio at 44.1kHz, and played without issue in ffmpeg, confirming full remote viewing capability with only the weak credential pair.

Finding 2 — Unauthenticated MQTT publish (High)

The Mosquitto broker on 1883/tcp accepted publish requests with no username or password supplied:

```
mosquitto_pub -h 192.168.50.20 -p 1883 \  
-t home/livingroom/light/set -m OFF  
mosquitto_pub -h 192.168.50.20 -p 1883 \  
-t home/livingroom/light/set -m ON
```

Both commands were accepted by the broker and the simulated light responded accordingly, confirming that any client able to reach TCP/1883 can issue control commands without authentication.

Finding 3 — Node-RED editor exposure (High — unconfirmed)

Nmap's HTTP probe against 1880/tcp returned a 200 OK response containing OpenJS Foundation / Node-RED branding, confirming the editor is reachable on the LAN. Authentication was not tested in this phase (see Section 5.1); recommend a dedicated follow-up test of the adminAuth configuration in settings.js before this finding is closed or downgraded.

Finding 4 — Unencrypted MQTT traffic (Medium)

A packet capture on the MQTT port confirmed that both the protocol handshake and the application payload — topic and message content — are visible in clear text:

```
sudo tcpdump -i eth0 -nn -A tcp port 1883
...
192.168.50.10.47960 > 192.168.50.20.1883: ... length 32
home/livingroom/light/setOFF
192.168.50.10.36426 > 192.168.50.20.1883: ... length 31
home/livingroom/light/setON
```

31 packets were captured across the two publish actions, with topic and payload fully legible in the packet contents — no TLS (port 8883) listener was in use.

Finding 5 — \$SYS broker information disclosure (Low)

Nmap's MQTT NSE script retrieved internal broker statistics from the \$SYS topic tree without providing credentials, including: clients/active (3), clients/connected (3), clients/total (5), subscriptions/count (8), and retained messages/count (56).

Finding 6 — Unnecessary MediaMTX surface (Low)

Beyond the RTSP stream itself, MediaMTX exposed three further HTTP(S) listeners (8888, 8889, 8892) returning "Server: mediamtx" banners and standard 404 responses, plus a self-signed TLS certificate on 8892 valid for a ten-year period (2026-08-28 to 2036-08-25) — well outside recommended certificate lifetimes.

Full Service Enumeration

Port / Service	Identified As
1880/tcp	Node-RED (home automation editor) — OpenJS Foundation web interface, HTTP 200
1883/tcp	Mosquitto MQTT broker, version 2.1.2
1935/tcp	RTMP (unidentified by version scan)
8554/tcp	RTSP camera stream (misidentified by Nmap's service DB as "Identifier NameTracer Pro httpd")
8888, 8889/tcp	MediaMTX — Golang net/http server
8892/tcp	MediaMTX — SSL/HTTP, self-signed cert, CN=mediamtx, 10-year validity

5.3 Technical Remediation Guidance

Finding	Recommended Technical Remediation
1. Camera credentials	• Replace default credentials with a strong, unique password per camera. • Restrict TCP/8554 at the firewall/VLAN level to only the NVR or automation hub IP, not the full LAN. • Enable RTSPS (RTSP over TLS) if supported by the camera firmware; otherwise tunnel remote access through a VPN rather than exposing the stream directly. • Apply outstanding firmware updates.
2. Unauthenticated MQTT publish	• Set <code>allow_anonymous</code> false in <code>mosquitto.conf</code>. • Provision per-device credentials with <code>mosquitto_passwd</code> and a <code>password_file</code>. • Apply topic-level ACLs (<code>acl_file</code>) so each client can only publish/subscribe to its own topic namespace. • Rotate credentials on a regular schedule and after any suspected exposure.
3. Node-RED exposure	• Enable <code>adminAuth</code> in <code>settings.js</code> with bcrypt-hashed credentials — do not run the editor unauthenticated. • Bind the editor to localhost/internal-only interfaces and access it via SSH tunnel or VPN rather than exposing 1880 broadly on the LAN. • Review deployed flows for hard-coded secrets and restrict <code>functionGlobalContext</code> / Function node usage if not required.
4. Unencrypted MQTT traffic	• Enable a TLS listener on 8883 with a valid certificate (server-auth at minimum; mutual TLS for higher assurance). • Disable or restrict the unencrypted 1883 listener to localhost once all clients have migrated to TLS.
5. \$SYS information disclosure	• Restrict subscription to <code>\$SYS/#</code> to an authenticated admin user via ACL; anonymous/unauthenticated clients should not receive broker telemetry.
6. MediaMTX exposed surface	• Disable unused API/metrics listeners (8888/8889) if not actively consumed. • Place any administrative or metrics endpoint behind authentication. • Replace the long-dated self-signed certificate with one from an internal CA or a short-lived cert, and confirm TLS configuration disallows weak ciphers. • Firewall these ports to the automation subnet only.
7. Flat network / no segmentation	• Create a dedicated VLAN and SSID for IoT/smart-home devices, isolated from trusted personal devices.

Finding	Recommended Technical Remediation
	• Apply firewall rules blocking east-west traffic into the IoT VLAN except explicitly required flows (e.g. hub ↔ broker). • Block all unsolicited inbound access to the IoT VLAN from the internet; avoid port-forwarding.

5.4 Notes and Limitations

- This assessment covered host discovery, port/service enumeration, MQTT interaction, MQTT traffic capture, and RTSP stream validation only. It did not include authentication testing against the Node-RED editor, firmware/binary analysis, physical security testing, or wireless (Wi-Fi) security testing.
- A physical door lock device was added to the home's network after this assessment was completed and was not in scope; it should be included in the next assessment cycle.
- Findings should be re-validated after remediation, particularly Finding 3, which requires confirmation of the Node-RED authentication state before it can be downgraded or closed.